

Bachelor Thesis

Nsak as Framework for Scenario Based Network Security

Course of study	Bachelor of Science in Computer Science
Author	Frank Gauss (gausf1) and Lukas von Allmen (vonal3)
Advisor	Wenger Hansjürg

Version 1.0 of March 10, 2026

Abstract

One-paragraph summary of the entire study – typically no more than 250 words in length (and in many cases it is well shorter than that), the Abstract provides an overview of the study.

Contents

Abstract	ii
1. Introduction	1
1.1. Motivation	1
1.2. Project Goals	1
1.2.1. Research Goals	2
1.2.2. Framework	3
1.2.3. Scenarios	5
1.2.4. Evaluation Goals	7
1.2.5. Out of Scope / Optional Feature	8
2. Related Research	9
2.1. Comparison Nsak - Caldera	9
3. Concepts - Framework	10
4. Methodology	11
5. Implementation	12
6. Evaluation	13
7. Discussion	14
8. Conclusion	15
Bibliography	16
List of Figures	17
List of Tables	18
List of Listings	19
Glossary	20
A. Project Management	21
A.1. Agile Management Process	21

A.2. Definition of Ready (DoR)	21
A.3. Definition of Done (DoD)	22
A.4. Project Structure	23
A.5. Planning and Estimation	23
A.6. Project Roadmap	23
A.6.1. Risk Assessment	25
A.7. Meeting Notes	30
A.8. Workshops	33
A.8.1. Brainstorm Scenario Selection	33
A.8.2. NSAK Scenario: Network Discovery - Red Team	34
A.8.3. NSAK Scenario: TLS Downgrade Poodle - Red Team	35
A.8.4. NSAK Scenario: Honeypot - Blue Team	37
A.8.5. NSAK Scenario: Traffic Capture - Red Team	38
A.8.6. NSAK Scenario: Intrusion Detection - Blue Team	39
A.9. Self-Hosted LLM	41
A.9.1. Hardware Setup	41
A.9.2. System Setup	41
A.9.3. Evaluation	47

1. Introduction

Computer networks are constantly exposed to evolving cyber threats ...

The *Network Swiss Army Knife (NSAK)* is a framework designed to execute orchestrated security scenarios consisting of reusable attack drills in a controlled network environment. The framework aims to support automated security testing and adversary emulation on network edge devices.

The development of the NSAK framework originates from previous project work, in which the core architecture and the basic scenario execution model were developed. This thesis builds upon this foundation and extends the framework by investigating how AI agents can support automated red and blue team scenarios.

...

1.1. Motivation

Hypothesis: AI can enhance red and blue team simulations in a network environment by generating and executing scenarios within the NSAK framework and assisting in the evaluation of detection results.

1.2. Project Goals

For a goal to be considered **S.M.A.R.T.**, it must fulfill the following criteria:

- ▶ **Specific:** What do we want to achieve?
- ▶ **Measurable:** What are the success criteria?
- ▶ **Achievable:** How do we plan to achieve this goal?
- ▶ **Relevant:** Why is it important to achieve this goal?
- ▶ **Time-bound:** Goals categorized as *must* have to be achieved within the thesis, while *should* or *could* goals are considered optional or nice to have.

1.2.1. Research Goals

Compare Frameworks (must)

To identify the USP (unique selling point) of the NSAK framework, we will analyze and compare existing security emulation frameworks. First, relevant frameworks such as MITRE Caldera and Atomic Red Team will be identified and reviewed. Based on this analysis, the identified concepts will be compared with the architecture of the NSAK framework. The comparison will focus on how scenarios and drills are defined, how configuration and parameter handling are structured, how reusable components are organized, how automation is achieved, and which AI capabilities they provide.

The analysis and comparison will be based on the following properties:

- ▶ Concepts
- ▶ Modularity
- ▶ Configurability
- ▶ Automation
- ▶ AI Capabilities

Success criteria:

- ▶ At least two security emulation frameworks are identified and reviewed
- ▶ A matrix comparing the specified properties of the selected frameworks is created
- ▶ The USP of the NSAK framework is identified

AI Integration (must)

The goal of this research is to investigate how AI (artificial intelligence) can support automated security testing and adversary emulation. The research evaluates potential integration points where AI could enhance the scenario execution, automation, decision-making, and analysis capabilities of the NSAK framework.

Success criteria:

- ▶ How is AI currently used in cybersecurity automation?
- ▶ Which tasks in adversary emulation can be supported or automated by AI?

- ▶ How could AI interact with the NSAK scenarios and drills (e.g., Agents, MCP)?
- ▶ What architectural changes would be required to integrate AI into NSAK?

1.2.2. Framework

Configuration Management (must)

The goal is to extend the NSAK framework, so that scenarios and drills can expose configurable parameters to increase the flexibility of scenarios and reusability of drills. Parameters can be provided via command-line arguments or YAML files and are resolved by the framework into a unified run configuration used for scenario execution.

Success criteria:

- ▶ Scenarios and drills can expose configurable parameters
- ▶ The available parameters can be listed by the CLI with the `--help` option
- ▶ Parameters can be provided via CLI arguments or YAML files
- ▶ The framework resolves the inputs into a run configuration (internal data structure).

REST API (TBD)

Adding a REST API to the NSAK framework was already proposed in the predecessor project, as it greatly enhances interoperability with other tools. The priority of this goal depends heavily on the outcome of the goal 1.2.1 and on whether we want to fulfill the goal 1.2.2, which is prioritized as “could”. If the evaluated AI integration requires a REST API (e.g., MCP), this goal needs to be prioritized as “must”; it will be prioritized as “could”.

Success criteria:

- ▶ A REST API specification with feature parity to the CLI is created.
- ▶ The REST API is implemented according to the specification.
- ▶ The API is documented (Open API) and usable by external clients.
- ▶ The REST API remains optional and does not replace the CLI-based interaction.

- ▶ Authentication and Authorization are explicitly out of scope.

MCP Server (TBD)

The MCP Protocol allows the AI to interact with applications in a standardized way - and could therefore be necessary for implementing AI-based scenarios. If the outcome of the research task [1.2.1](#) highlights the necessity to specify/expose an MCP-Server to interact seamlessly with the NSAK framework, the implementation is a (must), otherwise a (could).

- ▶ A MCP-Server is specified and implemented
- ▶ Documentation how to connect to the MCP is provided.
- ▶ A form of authentication is provided.

Web GUI (could)

The goal is to design and implement a web-based graphical user interface that allows users to interact with the NSAK framework in a user-friendly way. The Web GUI will enable management of scenarios and drills, triggering scenario execution, and visualization of execution results and system status.

Success criteria:

- ▶ A simple Web GUI that interacts with the REST API has been implemented.
- ▶ The Web GUI displays a list of available scenarios and their states.
- ▶ The scenario's results can be viewed on the Web GUI
- ▶ Scenarios can be configured and executed via the Web GUI
- ▶ Authentication and authorization are explicitly out of scope.

1.2.3. Scenarios

AI – Purple Team (must)

The goal is to implement artificial intelligence according to the result of 1.2.1 and to explore the use of AI to support red, blue, and purple team exercises in the NSAK framework. The AI will be evaluated for its potential to assist in executing attacks in a scenario and analyzing detection results. The findings will help assess how AI could enhance and coordinate red and blue team activities across a network via the NSAK device.

Success criteria:

- ▶ The AI is integrated into NSAK as a scenario or as part of the framework, depending on the result of 1.2.1.
- ▶ The AI can execute CLI or Python tools to directly or indirectly interact with the attached network.
- ▶ An operator can interact with or stop the running AI.
- ▶ The result artifacts are stored and can be presented or reused for further scenarios.

Reproducible Test Environment (must)

The goal is to design and implement a reproducible and safe test environment for the NSAK framework that enables consistent execution and evaluation of scenarios and drills. The environment should provide a stable basis for testing and comparison of manual and AI-assisted scenarios.

Success criteria:

- ▶ The test environment can be set up reproducibly using a defined configuration or setup procedure with Infrastructure as code (e.g., Ansible)
- ▶ NSAK scenarios and drills can be executed consistently within the environment.
- ▶ The environment supports both manual and AI-assisted scenarios.
- ▶ Scenario results can be collected and analyzed for evaluation purposes.

Network Discovery – Red Team (must)

The goal is to implement a reference red team scenario for network discovery within the NSAK framework. The scenario should simulate reconnaissance activities to identify hosts, services, and network characteristics, and the results should be comparable to the AI-Agent approach.

Success criteria:

- ▶ A red team network discovery scenario is implemented in the NSAK framework.
- ▶ Discovered network information is collected as artifacts.
- ▶ The scenario can be executed reproducibly within the test environment.
- ▶ The results can be compared with those generated by the AI-assisted approach.

Intrusion Detection – Blue Team (should)

The goal is to define and implement a blue team reference scenario for intrusion detection within the NSAK framework. The scenario should allow observation and evaluation of suspicious network activity to assess detection capabilities in the test environment and compare the results with those of the AI approach.

Success criteria:

- ▶ A blue-team intrusion-detection scenario is implemented in the NSAK framework.
- ▶ Detection events or alerts can be observed and documented during scenario execution.
- ▶ Detection results can be compared with results from AI-assisted scenario execution.

1.2.4. Evaluation Goals

AI Scenario (must)

The objective is to determine the effectiveness of the AI-based scenario introduced by the goal 1.2.3 within the network environment defined by the goal 1.2.3. The evaluation will assess whether the AI scenario successfully executed the expected red and blue team activities for the provided prompts and the quality of the results.

Success criteria:

- ▶ A methodical approach for the assessment is evaluated and documented.
- ▶ The results of the AI scenario for red and blue team activity are assessed.
- ▶ There is a conclusion on the effectiveness of the AI scenario for red and blue team activities.

AI vs Engineered Scenarios (must/should)

The goal of this evaluation is to compare the quality of AI-based red (network reconnaissance) (must) and blue (network intrusion detection) (should) team scenarios with that of manually engineered scenarios.

The comparison focuses on criteria such as execution reliability, reproducibility, and coverage. The results will help determine the potential benefits and limitations of AI-supported scenarios and provide insights into how AI could enhance future versions of the NSAK framework.

Success criteria:

- ▶ A methodical approach for the comparison is evaluated and documented.
- ▶ The results of the AI scenario are compared against the respective results of the red team scenario (must)
- ▶ The results of the AI scenario are compared against the respective results of the blue team scenario (should)
- ▶ There is a conclusion on the effectiveness of the AI scenario compared to manually engineered scenarios.

1.2.5. Out of Scope / Optional Feature

At the project management meeting on 05.03.26 (see Table ?? in Appendix A.7), the initial project scope was discussed. During planning, the team proposed using AI-based scenarios and comparing them with the implemented versions, which required reassessing certain milestones.

Running AI-based scenarios does not require a REST API or GUI. A reproducible test setup and further research are needed to properly evaluate this approach.

2. Related Research

2.1. Comparison Nsak - Caldera

3. Concepts - Framework

4. Methodology

5. Implementation

6. Evaluation

7. Discussion

8. Conclusion

Bibliography

- [1] Advisera. Iso 27001 risk assessment, treatment, and management: The complete guide, 2025. Accessed: 2026-03-04.
- [2] Simplr. General recommended vram guidelines for llms, 2025. Online; accessed 10 March 2026.

List of Figures

A.1. Roadmap	24
A.2. Risks Brainstorming	27
A.3. Risks Brainstorming	28
A.4. Risk Assessment	29
A.5. Brainstorm Scenarios	33
A.6. Clustering possible Scenarios	34
A.7. NSAK Scenario: Network Discovery - Red Team	35
A.8. NSAK Scenario: TLS Downgrade Poodle - Red Team	36
A.9. NSAK Scenario: TLS Downgrade Poodle -Topology	37
A.10.	38
A.11.	39
A.12.	40
A.13. FRITZ!Box DynDNS Setup	45
A.14. Infomaniak DynDNS Setup	46
A.15. FRITZ!Box DynDNS Setup	46
A.16. FRITZ!Box DynDNS Setup	47

List of Tables

A.1. Risk categories used for the project risk assessment	25
A.2. Risk evaluation criteria	25
A.3. Risk probability scale	26
A.4. Risk impact scale	26
A.5. Risk level classification (probability and impact are interchangeable)	26
A.6. Risk Treatment Strategies	28
A.7. Meeting Notes: Checkpoint 1	30
A.8. Meeting Notes: Checkpoint 2	31

Listings

A.1. UFW configuration	41
A.2. /home/ai/docker-compose.yml	42
A.3. swag/nginx/site-confs/default.conf	43
A.4. UFW configuration	44
1. Example Python Script ⁴⁷	

Glossary

This document is incomplete. The external file associated with the glossary ‘main’ (which should be called `thesis.gls`) hasn’t been created.

Check the contents of the file `thesis.gls`. If it’s empty, that means you haven’t indexed any of your entries in this glossary (using commands like `\gls` or `\glsadd`) so this list can’t be generated. If the file isn’t empty, the document build process hasn’t been completed.

If you don’t want this glossary, add `nomain` to your package option list when you load `glossaries-extra.sty`. For example:

```
\usepackage[nomain]{glossaries-extra}
```

Try one of the following:

- ▶ Add `automake` to your package option list when you load `glossaries-extra.sty`. For example:

```
\usepackage[automake]{glossaries-extra}
```

- ▶ Run the external (Lua) application:

```
makeglossaries-lite.lua "thesis"
```

- ▶ Run the external (Perl) application:

```
makeglossaries "thesis"
```

Then rerun $\text{\LaTeX}$ on this document.

This message will be removed once the problem has been fixed.

A. Project Management

A.1. Agile Management Process

The project followed an interactive development approach using Gitlab for issue tracking and planning. We defined our project management in a Scrum-like manner, but we individualized the process according to the projects scope and our needs. Work items were organized into epics, milestones and issues. Each iteration lasts two weeks. We decided to hold the following Scrum ceremonies after each sprint:

- ▶ Sprint planning
- ▶ Sprint review
- ▶ Sprint retro

The workflow used for ticket tracking consisted of the following stages:

Issue Lifecycle:

- ▶ Backlog
- ▶ Todo
- ▶ Q&A
- ▶ Done

A.2. Definition of Ready (DoR)

A ticket is considered ready for implementation when the following criteria are fulfilled.

Clarity:

- ▶ Clear and precise title
- ▶ Objective or problem described in two to three sentences

- ▶ Scope clearly defined

Scope:

- ▶ Affected module specified (drill, scenario, core, container, frontend)
- ▶ External dependencies identified

Validation:

- ▶ Testable acceptance criteria defined
- ▶ Expected behavior clearly specified

A.3. Definition of Done (DoD)

A ticket is considered done when all the following criteria are fulfilled.

Implementation:

- ▶ All acceptance criteria fulfilled
- ▶ Container execution verified
- ▶ Pre-commit hooks pass
- ▶ Logging and error handling consistent

Testing:

- ▶ Feature or bug fix tested
- ▶ Acceptance criteria verifiable (automated or manual)
- ▶ Relevant edge cases considered
- ▶ Execution reproducible

Documentation:

- ▶ README updated if required
- ▶ Architecture changes documented
- ▶ Thesis relevance briefly noted

- ▶ Limitations documented
- ▶ Required documentation stored for thesis or appendix

A.4. Project Structure

Milestones represent crucial steps toward the overall project goal. Per our definition a milestone has at least one epic.

Epics consist of multiple stories and contribute to fulfilling milestones.

Stories Each story is assigned a weight, sprint, milestone and epic and are usually represented by an “Issue” in gitlab. While Gitlab differences between “Task” and “Issue”, the terms are often used interchangeably with “Stories”. Stories must meet the [A.2](#) before implementation and [A.3](#) before closing.

A.5. Planning and Estimation

The following estimation strategy was used:

- ▶ 1 hour corresponds roughly to 1 weight point
- ▶ Iteration length: 2 weeks
- ▶ Weights per iteration: 40h per person = 80 weight per iteration
- ▶ Sprint planning duration: 1.5 hours per iteration
- ▶ Sprint review duration: 1 h per iteration
- ▶ Sprint retro duration: 1 h per iteration

A.6. Project Roadmap

The introduced project structure is illustrated in the roadmap shown in Figure [A.1](#). The structure shown in [A.4](#) helps to visualize the project goals and keeps track of the progress towards achieving goals and milestones. Furthermore, the visualization helps stakeholders to grasp the current state of the project.

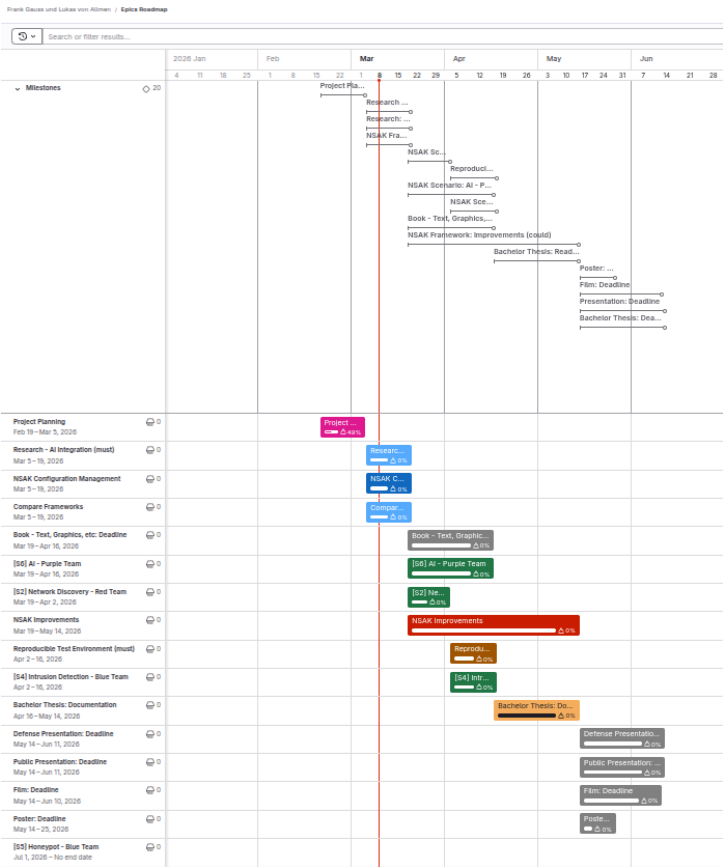


Figure A.1.: Roadmap

Rewrite
in past
tense

A.6.1. Risk Assessment

To methodically conduct the risk assessment the section “Risk assessment” from an online guide published by Advisera [1], which describes the risk assessment process according to ISO 27001, was used as a reference.

Risk Assessment Process:

1. Risk categories and criteria: Define which dimensions and taxonomies are important for the assessment.
2. Risk identification: Collect possible risks in a brainstorming session.
3. Risk analysis: Assess the risks criteria on a risk matrix.
4. Risk evaluation: Create a list of risks ordered by the resulting risk level and evaluate if they are acceptable or need treatment.
5. Risk treatment: Describe the strategy and how to treat the risks.

Risk Categories & Criteria:

The table A.1 shows four commonly used categories, which were used to group the risks.

Category	Description
Strategic Risk	Risks related to business decisions (e.g., wrong prioritization).
Operational Risk	Risks related to internal processes (e.g., Scrum, QA process).
Financial Risk	Risks related to costs and expenses (e.g., hardware costs).
External Risk	Risks related to uncontrollable sources (e.g., force majeure).

Table A.1.: Risk categories used for the project risk assessment

The criteria for analysing the risks are summarized in the table A.2

Criterion	Description
Probability	Likelihood that the risk will occur.
Impact	Severity of consequences if the risk materializes.
Level	Risk level calculated as Probability + Impact.

Table A.2.: Risk evaluation criteria

The levels of the criteria and their respective numerical weights are listed in the tables A.3 and A.4.

Level	Weight	Description
Low	1	Unlikely
Medium	2	Possible
High	3	Likely

Table A.3.: Risk probability scale

Level	Weight	Description
Low	1	Minor inconveniences
Medium	2	Delays milestones or reduces scope
High	3	Threat to the thesis

Table A.4.: Risk impact scale

The following table [A.5](#) defines the calculation method and the resulting risk levels, used for the assessment.

Risk Level	Weight	Calculation
Very Low	2	Low + Low
Low	3	Low + Medium
Medium	4	Medium + Medium / Low + High
High	5	Medium + High
Critical	6	High + High

Table A.5.: Risk level classification (probability and impact are interchangeable)

Risk Identification

The identification process was conducted with the help of a digital brainstorming, where the risks are already grouped by category. The identified risks are represented by the cards shown in [A.2](#). The respective risk categories are visualized by the color coding of the cards and described in the legend.

Risk Brainstorming

- **Strategic Risk:** Risks related to business decisions (e.g. wrong prioritization).
- **Operational Risk:** Risks related to internal processes/procedures (e.g. Scrum, QA process).
- **Financial Risk:** Risks related to costs and expenses (e.g. hardware costs).
- **External Risk:** Risks related to uncontrollable sources (e.g. Force majeure).

An existing framework already does everything we have planned	Not enough time for testing (drills, scenarios and environments)	Not enough time for media artifacts (Poster, Presentations, Film, Book, etc.)	Lack of resources/ consensus for defense scenarios	Complex Network environments need more hardware than available	One of the students gets injured or sick
Misaligned communication lead to wrong expectations	Not enough time for documentation	Drills not compatible between scenarios	Lack of resources for attack scenarios	AI Credits are too expensive to build and test the AI scenario	NSAK gets abused by hackers
Scope is too large for bachelor thesis	Scenarios and drills need more time as planned	Regressions: Tested scenarios stop working, because a drill was changed	User do not understand how to operate NSAK	The NSAK hardware devices stop working	The AI bubble bursts and we need to switch AI provider
Scenario or drill too complex for automation	Simulate or build network environments need more time as planned	The NSAK framework/ device itself is vulnerable	The AI might go rough in the AI scenario		

Figure A.2.: Risks Brainstorming

Risk Analysis

For analysing the risks a matrix was prepared, where the criteria “Impact” and “Probability” are representing the x- and y-axis respectively. The project team then assessed the criteria for each individual risk and placed them on the matrix accordingly. In a second step, the risks where moved if they did not fit relatively to each other. The resulting “Risk Analysis Matrix” is illustrated in the following figure A.3. The background color of the cells is representing the resulting risk level of the tasks.

Risk Matrix

Probability	High	The NSAK framework/device itself is vulnerable User do not understand how to operate NSAK Regressions: Tested scenarios stop working, because a drill was changed Not enough time for testing (drills, scenarios and environments) Simulate or build network environments need more time as planned AI Credits are to expensive to build and test the AI scenario
	Medium	An existing framework already does everything we have planned The AI might go rough in the AI scenario Complex Network environments need more hardware than available Scenarios and drills need more time as planned Not enough time for documentation Scope is too large for bachelor thesis Drills not compatible between scenarios Misaligned communication lead to wrong expectations The AI bubble bursts and we need to switch AI provider Not enough time for media artifacts (Poster, Presentations, Film, Book, etc.) Scenario or drill to complex for automation
	Low	Lack of resources for attack scenarios Lack of resources/consensus for defense scenarios The NSAK hardware devices stop working NSAK gets abused by hackers One of the students gets injured or sick
		Low Medium High
		Impact

Figure A.3.: Risks Brainstorming

Risk Evaluation & Treatment

In a first step a table with the required columns was created. Then the risks and weights for the criteria were added with an ID in the format “R-000”, to easier reference them in the thesis later on. After sorting the table by the calculated risk level, the risk evaluation was conducted by deciding which treatment strategy described in A.6 we want to apply.

Strategy	Description
Mitigate	Reduce the likelihood or impact of a risk.
Transfer	Move the risk to a third party.
Accept	Acknowledge the risk and take no further action.
Avoid	Eliminate or circumvent the cause of the risk.

Table A.6.: Risk Treatment Strategies

Finally, the project team went through the risks and discussed how to treat them effectively. The resulting “Risk Assessment” is illustrated in the following table A.4.

Figure A.4.: Risk Assessment

Risk Assessment									
Risk ID	Description	Criticality			Severity			Strategy	Treatment
		Criticality		Likelihood	Severity		Impact		
		High	Low		High	Low			
		3 - Medium	2 - Medium		3 - High	2 - Low			
		3 - High	2 - Medium		1 - Low	1 - Critical			
R001	AI models are too expensive to build and test the AI scenario	Financial	3	3	9	Avoid	Use a self-hosted LLM, check if the B2B can provide AI services or if there are free plans for education		
R006	Scripts are too large to transfer them	Strategic	2	3	6	Mitigate	We have to plan and evaluate the gaps carefully. The use of 'User Story Maps' also helps to mitigate the risk.		
R007	Scenario or role too complex to automation	Strategic	2	3	6	Mitigate	Create 'User Story Maps' for actors so that we have a good understanding of the scenarios and their roles.		
R002	Not enough time for documentation	Operational	2	3	6	Mitigate	Add a dedicated documentation issue with an according weight to each epic.		
R003	Not enough time for testing (defects, scenarios and environments)	Operational	3	2	6	Mitigate	Add a dedicated testing issue with an according weight to each epic.		
R004	Simulating or building network environments needs more time than planned	Operational	3	3	9	Mitigate	Add dedicated issues with according weight to each scenario epic.		
R005	User does not understand how to operate NSM4	Operational	3	2	6	Mitigate	Provide a 'What-DoU' and/or user guides		
R012	Misaligned communication leads to wrong expectations	Strategic	2	2	4	Mitigate	Multiple channels and Bi-Weekly Meetings should keep the communication aligned.		
R010	Scenarios and drafts need more time than planned	Operational	2	2	4	Mitigate	Use 'User Story Maps' to get a good idea of the required steps to build the scenario, it's drafts and estimate generously.		
R011	Not enough time for media artifacts (poster, presentation, film, book, etc.)	Operational	2	2	4	Mitigate	Include the creation of the media artifacts as sub-tasks/epics in the project planning.		
R009	Complex network environments need more hardware than available	Financial	2	2	4	Avoid	We can simulate network environments instead of real hardware.		
R008	The Attributable bursts are hard to switch AI provider	External	2	2	4	Avoid	Use vendor agnostic tools and protocols, so that we can switch provider easily.		
R014	Regulators' stated scenarios stop working because a draft was changed	Operational	3	1	3	Mitigate	Add a dedicated test cases for delivering responses early.		
R015	The NSM4 framework/device itself is vulnerable	Operational	3	1	3	Transfer	Clearly state that the NSM4 framework/device is still a POC and not ready for production use.		
R013	One of the students gets injured or sick	External	1	3	3	Accept	We accept this risk.		
R019	An existing framework already does everything we have planned	Strategic	2	1	2	Accept	We accept the risk, but will compare well known frameworks with NSM4 and highlight our USP (HW and AI).		
R017	Drafts not compatible between scenarios	Operational	2	1	2	Mitigate	The implementation of the configuration management should provide a way that small deviations can be handled.		
R016	The AI might go rogue in the AI scenario	Operational	2	1	2	Mitigate	Besides the fact that we have physical access to the device we add a sub-task to run AI scenario.		
R018	The NSM4 hardware devices stop working	Financial	1	3	3	Accept	The fact that we have two devices already reduces the impact. Further we could also use other HW.		
R021	Lack of resources for alpha scenarios	Operational	1	1	1	Mitigate	Get familiar and use the MITRE ATT&CK framework as reference and source.		
R022	Lack of resources / consensus for different scenarios	Operational	1	1	1	Mitigate	Get familiar and use well known sources such as NIST as source.		
R020	NSM4 gets studied by hackers	External	1	1	1	Transfer	Clearly state that the NSM4 framework/device is built only for educational and white-hat purposes.		

A.7. Meeting Notes

Participants	Hj. Wenger (Instructor), Frank Gauss, Lukas von Allmen
Agenda	- Goals presentation via slides - Clarification whether there is a deadline or submission required for the presentation (besides adding it to the addendum). - Clarification whether the defense presentation should be an enhanced version of the public presentation or a separate, more technical presentation. - Proposal to establish a recurring meeting series every Thursday at 15:00 during the semester.
Tasks	- Hand in a set of success criteria for the project goals: We thought we can deliver the success criteria and the project goals as milestones in gitlab, we corrected this later on. - Conduct a risk assessment: A.6.1

Table A.7.: Meeting Notes: Checkpoint 1

Meeting Notes Nsak Checkpoint - 26.02.26

Participants	Hj. Wenger (Instructor), Urs Keller (Expert), Frank Gauss, Lukas von Allmen
Agenda	- Review of the project goals as milestones and project planning. - Review of risk assessment. - Discussion on the investigation and analysis of network communication between end devices and external networks (RED scenario: sniffing, filtering, and potential data exfiltration).
Decisions	- Variant 1 was selected for further development. - Open questions remain regarding the use and management of AI tokens.
Notes	- We misunderstood how to deliver the project goals and success criteria: Instead of defining the goals as milestone we added a goal section in the thesis. - Discussion on the rationale behind selecting Variant 1. - Consideration of whether a user interface is required when MCP functionality is available - Open Research Question. - NSAK integrates AI capabilities. - The development of a Web GUI is currently considered lower priority - suggestion of Urs Keller.
Tasks	- Send the slides of the final presentation and documentation of "Project 2" to Urs Keller (Expert). - Delivery the projects goals with a detailed description as part of the thesis by Saturday, 07.03.26: 1.2 - Finalize the project planning: A.6 - Write the first few chapters of the thesis:

Table A.8.: Meeting Notes: Checkpoint 2

Meeting Notes Nsak Checkpoint - 05.03.26

Meeting Notes Nsak Checkpoint - 19.03.26

Meeting Notes Nsak Checkpoint - 02.04.26

Meeting Notes Nsak Checkpoint - 16.04.26

Meeting Notes Nsak Checkpoint - 30.04.26

Meeting Notes Nsak Checkpoint - 14.05.26

Meeting Notes Nsak Checkpoint - 28.05.26

Meeting Notes Nsak Checkpoint - 11.06.26

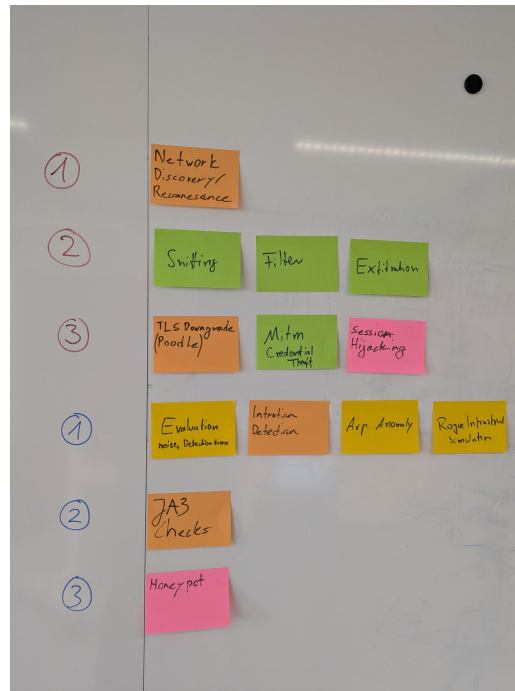


Figure A.6.: Clustering possible Scenarios

The Brainstorm session is used to derive further red/blue team scenarios and led to the pivot of AI-enabled Nsac scenario.

A.8.2. NSAK Scenario: Network Discovery - Red Team

Network Discovery Scenario

Objectives

This workshop aims to evaluate the different steps of the network discovery process and to help participants understand how attackers identify and map potential targets within a network.

Building on this objective, Red Teams consider network discovery one of the most essential activities during the reconnaissance phase, as it helps them identify hosts and services and evaluate potential targets. Once a network map is created, the team can use it in later phases. For example, they might execute an ARP spoofing attack, which allows them to intercept network traffic more efficiently.

In relation to these activities, this scenario addresses the following point from the thesis proposal:

‘Unterstützung typischer Vorgehensweisen aus dem Red-Team- und Penetration-Testing-Bereich, etwa durch Scan- oder Angriffssimulationen.’

The workshop led to the milestone *NSAK Scenario: Network Discovery – Red Team (must)*, in which each step for discovering and mapping a network is documented and structured for later implementation.

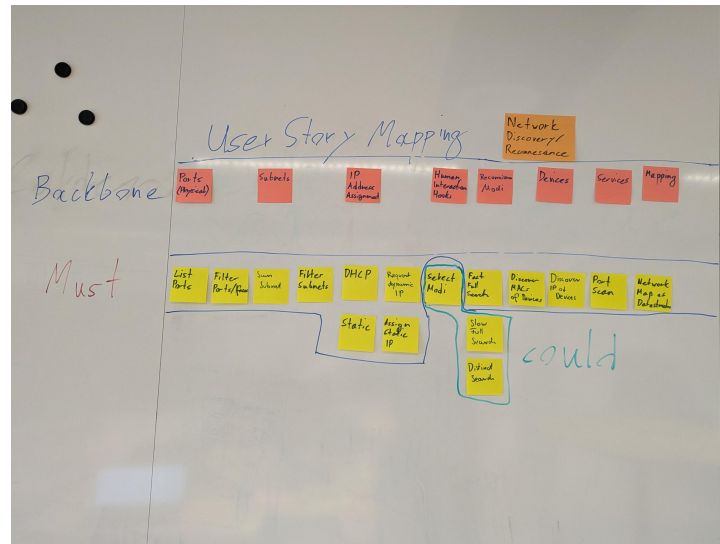


Figure A.7.: NSAK Scenario: Network Discovery - Red Team

A.8.3. NSAK Scenario: TLS Downgrade Poodle - Red Team

TLS Downgrade Poodle Milestone

Objectives

This workshop demonstrates how attackers can exploit TLS downgrade vulnerabilities, such as POODLE, to intercept encrypted communication.

In this scenario, the infamous POODLE attack is implemented, in which a malicious actor tries to convince a client and a server to use the vulnerable TLS version 1.1 instead of 1.2 or 1.3 to encrypt HTTP traffic. This attack requires the attacker to sit between the client and the server (a man-in-the-middle, or MITM), allowing them to intercept and control the traffic. When the client initiates a TLS handshake, the attacker drops packets to the server and sends TCP reset packets to the client, eventually trying older TLS versions. Because TLS 1.1 is vulnerable to a CBC Padding attack, it is possible to create a padding oracle that gradually decrypts the cookie and hijacks the user's session.

Building on this, the scenario directly addresses the following aspect from the thesis proposal:

‘Unterstützung typischer Vorgehensweisen aus dem Red-Team- und Penetration-Testing-Bereich, etwa durch Scan- oder Angriffssimulationen’

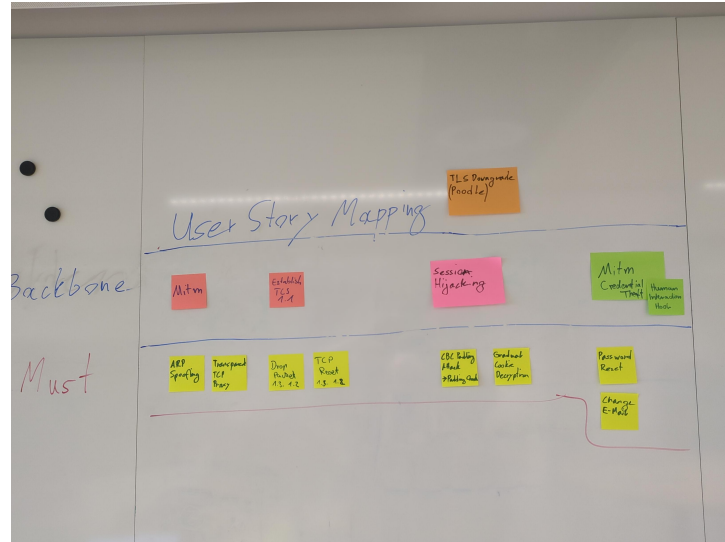


Figure A.8.: NSAK Scenario: TLS Downgrade Poodle - Red Team

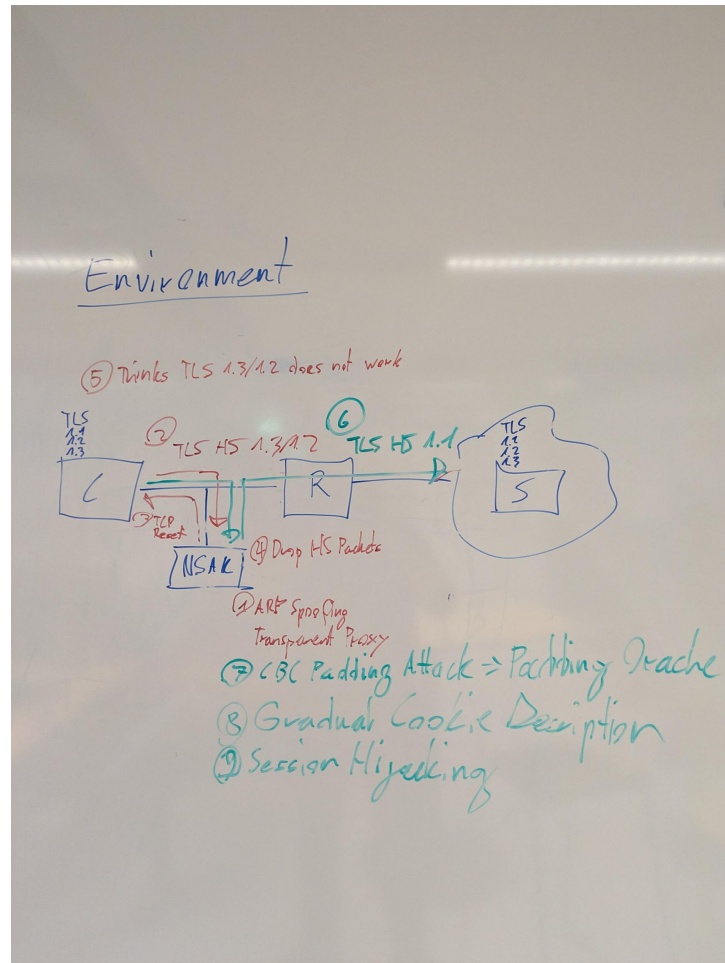


Figure A.9.: NSAK Scenario: TLS Downgrade Poodle -Topology

A.8.4. NSAK Scenario: Honeypot - Blue Team

Honeypot Milestone

Honeypots can serve as an additional form of intrusion detection and help Blue Teams detect attackers in a network. The system tries to attract malicious actors by providing an attack surface as large as possible; a simple way to achieve this is to open ports. After an attacker tries to connect to any of the open ports, the system notifies an operator and may close all open ports to prevent further attempts to compromise the Honeypot. The operator can then manually intervene to identify and isolate the attacker and analyze the captured payload.

This scenario covers the following bullet point from the thesis proposal:

‘Bereitstellung von Funktionen zur Erkennung, Protokollierung und Analyse verdächtiger

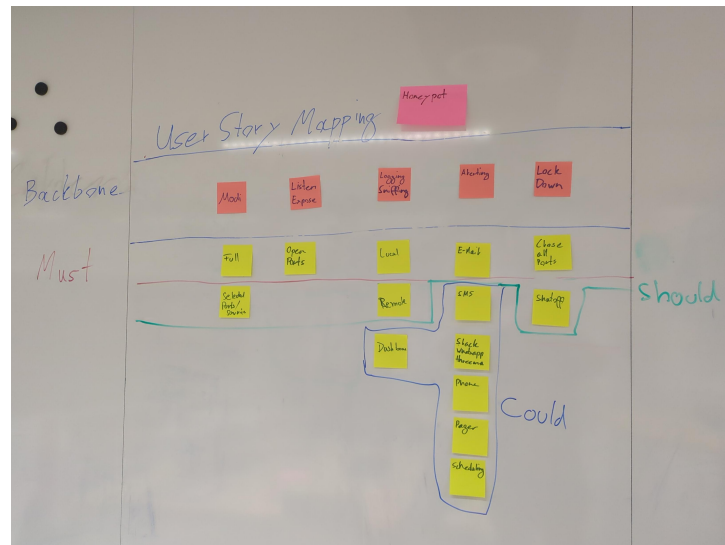


Figure A.10.

A.8.5. NSAK Scenario: Traffic Capture - Red Team

Traffic Capture Milestone

Capturing, exfiltrating, and analyzing traffic from a targeted network is a key Red Team activity and crucial for initial reconnaissance and planning the next phases of the attack. Based on the gathered intelligence, network participants and services can be identified, and possible attack vectors may be evaluated. If unencrypted traffic is present on the network, session data and credentials could already have been extracted.

This scenario addresses the following bullet point from the thesis proposal: ‘Untersuchung und Auswertung der Netzwerkkommunikation zwischen Endgeräten und externen Netzen.’



Intrusion detection is one of the core Blue Team activities and aims to identify malicious actors and misconfigured clients in production network environments. This can be achieved by introducing a system at a traffic mirroring port or as a central point in a network. The intrusion detection system can leverage a wide array of security policies, reference traffic, and other markers to effectively identify anomalies. As soon as suspicious activity is detected or a policy is violated, automated measures may be initiated, and security engineers will be automatically alerted for manual intervention.

This scenario covers the following bullet point from the thesis proposal: “Bereitstellung von Funktionen zur Erkennung, Protokollierung und Analyse verdächtiger Aktivitäten als Teil defensiver Massnahmen”



Figure A.12.

A.9. Self-Hosted LLM

During the risk assessment [A.6.1](#) we identified that the AI tokens required to use cloud based LLMs might be very expensive, and it's really hard to estimate the costs. One of the possibilities to avoid this risk was the usage of self-hosted LLMs, and luckily we already had existing hardware at home which is suitable for running smaller LLMs. Besides eliminating the costs for AI tokens, at least during the development phase, it also allows the quick evaluation of different AI Models. Depending on the quality and performance of the smaller models running in the self-hosted setup we can consider not using a cloud based LLM at all.

A.9.1. Hardware Setup

The 8 GB VRAM of the RTX 3070 allows us to run models with up to 7 billion parameters, depending on the specific model [\[2\]](#).

A.9.2. System Setup

The system setup described in [A.1](#) will configure and expose the Ollama API and OpenWeb UI via NGINX, which provided a chat GUI to interact with Ollama. In contrast to Ollama, which runs directly on the host, the other services are run in containers managed by rootless podman and defined the docker-compose.yml [A.2](#). The Nginx default.conf [A.3](#) configures the web server to terminate the SSL connection and act as reverse proxy for the “Open WebUI” and the Ollama API under the directory “/llm/”.

Services:

- ▶ Ollama: LLM manager, exposing an API for prompts and other interactions (host).
- ▶ Swag: Nginx web server with Certbot for automated SSL certificate generation (containerized).
- ▶ Open WebUI: Web based chat interface for LLM managers (containerized).

```

1  # Login as default user in sudoers or root user
2
3  # Check nvidia driver is loaded and the GPU was correctly detected
4  nvidia-smi
5
6  # Install Ollama and enable systemd service
7  sudo pacman -Syu ollama ollama-cuda
8  sudo systemctl enable --now ollama
9  sudo systemctl status ollama
10
```

Add
slided
if we
can re-
produce
them

```

11 # Download and run a qwen coder 7b model for testing
12 ollama pull qwen2.5-coder:7b
13 ollama list
14 ollama run qwen2.5-coder
15
16 # Create a new user for isolating the services
17 sudo useradd -m ai
18 sudo passwd ai
19
20 # Enable linger for user ai, required to run services such as rootless containers without being
    logged in
21 sudo loginctl enable-linger ai
22
23 # Edit the sysctl.conf file
24 sudo vim /etc/sysctl.conf
25
26 # Add the following lines, required for rootless podman to use the ports 443 and 80
27 net.ipv4.ip_unprivileged_port_start=443
28 net.ipv4.ip_unprivileged_port_start=80
29
30 # Load the new config
31 sudo sysctl -p
32
33 # Install podman and podman-compose
34 sudo pacman -Syu podman podman-compose
35
36 # Login as user ai and create the following directory and file
37 mkdir -p .config/containers
38 vim .config/containers/containers.conf
39
40 # Add the following lines, required for rootless podman (podman manages cgroups directly
    instead of systemd)
41 [engine]
42 cgroup_manager="cgroupfs"
43
44 # Create a docker compose file and add contents from lst:nginx-openwebui-docker-compose.yml
45 vim docker-compose.yml
46
47 # Start the services, so that they create the volume mappings etc, the containers will probably
    fail for now
48 podman-compose up -d
49 podman-compose down
50
51 # Open the nginx default.conf and add the contents from lst:nginx-default-conf
52 vim swag/nginx/site-confs/default.conf
53
54 # Start the services again, this time they should run successfully. Cevat:
55 # Certbot will fail to perform the http challenge for issueing the TLS certifiacte,
56 # as long as DynDNS and the port forwarding are not set up properly.
57 podman-compose up -d

```

Listing A.1: UFW configuration

```

1 services:
2   swag:
3     image: lscr.io/linuxserver/swag:latest
4     container_name: swag
5     cap_add:
6       - NET_ADMIN
7     environment:
8       - PUID=1000
9       - PGID=1000

```

```

10  - TZ=Europe/Zurich
11  - URL=hiube.ch
12  - VALIDATION=http
13  - SUBDOMAINS=ai,
14  - EMAIL=<my-email>
15  - ONLY_SUBDOMAINS=true
16  - EXTRA_DOMAINS= #optional
17  - STAGING=false #optional
18  - DISABLE_F2B= #optional
19  - SWAG_AUTORELOAD= #optional
20  - SWAG_AUTORELOAD_WATCHLIST= #optional
21  volumes:
22    - /home/ai/swag:/config
23  ports:
24    - 443:443
25    - 80:80 #optional
26    - 443:443/udp #optional
27  restart: unless-stopped
28
29  open-webui:
30    image: ghcr.io/open-webui/open-webui:main
31    container_name: open-webui
32    volumes:
33      - /home/ai/open_webui:/app/backend/data # Use a named volume for persistence
34    environment:
35      OLLAMA_BASE_URL: http://host.docker.internal:11434
36    restart: always

```

Listing A.2: /home/ai/docker-compose.yml

```

1  # redirect all traffic to https
2  server {
3      listen 80 default_server;
4      listen [::]:80 default_server;
5
6      server_name ai.hiube.ch;
7
8      location / {
9          return 301 https://$host$request_uri;
10     }
11 }
12
13 # main server block
14 server {
15     listen 443 ssl default_server;
16     # listen 443 quic reuseport default_server;
17     listen [::]:443 ssl default_server;
18     # listen [::]:443 quic reuseport default_server;
19
20     server_name ai.hiube.ch;
21     include /config/nginx/ssl.conf;
22     root /config/www;
23     index index.html index.htm index.php;
24
25     # enable subfolder method reverse proxy confs
26     # include /config/nginx/proxy-confs/*.subfolder.conf;
27
28     # Reverse proxy for Open WebUI
29     location / {
30         proxy_pass http://open-webui:8080;
31         proxy_set_header Host $host;
32         proxy_set_header X-Real-IP $remote_addr;

```

```

33     proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
34     proxy_set_header X-Forwarded-Proto $scheme;
35     # Required for WebSockets
36     proxy_http_version 1.1;
37     proxy_set_header Upgrade $http_upgrade;
38     proxy_set_header Connection "upgrade";
39     proxy_read_timeout 900s;
40     proxy_send_timeout 900s;
41 }
42
43 # Reverse proxy for Ollama
44 location /llm/ {
45     # This section enforces HTTP Basic Authentication
46     auth_basic "Restricted_Access";
47     auth_basic_user_file /etc/nginx/.htpasswd; # Path to credentials file inside the
container
48
49     # If authentication is successful, forward the request to Ollama
50     # The trailing slash is important, so that ollama does not see the /llm/ as part of the
path!
51     proxy_pass http://host.docker.internal:11434/;
52     proxy_set_header Host $host;
53     proxy_set_header X-Real-IP $remote_addr;
54     proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
55
56     # Increase timeouts for slow model responses to prevent 504 Gateway Timeout errors
57     proxy_connect_timeout 300s;
58     proxy_send_timeout 300s;
59     proxy_read_timeout 300s;
60 }
61 }
62
63 # enable subdomain method reverse proxy confs
64 # include /config/nginx/proxy-confs/*.subdomain.conf;

```

Listing A.3: swag/nginx/site-confs/default.conf

System Hardening

It is recommended to put a proper firewall before the services we want to expose to the internet, but for our purposes we can just disable the port forwarding when we don't use the AI. It still makes sense to perform a minimal system hardening as shown in the following listing [A.4](#), before exposing the services to the internet.

```

1 # Install UFW
2 sudo pacman -Syu ufw
3 sudo ufw status
4
5 # Allow all outgoing connections
6 sudo ufw default allow outgoing
7
8 # Deny all incoming connections per default
9 sudo ufw default deny incoming
10
11 # Allow SSH for remote access
12 sudo ufw allow ssh
13
14 # Allow HTTP for certbot HTTP challenge

```



```

15 sudo ufw allow http
16
17 # Allow HTTPS for Open WebUI
18 sudo ufw allow https
19
20 # Allow default Ollama port
21 sudo ufw allow 11434/tcp
22
23 # Make sure to run this command after adding the "allow" rules!
24 sudo ufw enable
25
26 sudo ufw status

```

Listing A.4: UFW configuration

Expose Open WebUI and Ollama

For exposing the services from the home network via HTTPS to the internet, we need a domain name which points to the home router. To achieve this we can use DynDNS, which is provided for free by Infomaniak where the domain “hiube.ch” was registered, and is supported by the FRITZ!Box used in the home network. The screenshots A.14 and A.13 are showing the respective configurations.

FRITZ!Box 5530 Fiber

Internet > Freigabe

Portfreigabe FRITZ!Box-Dienste **DynDNS** VPN (IPSec) VPN (WireGuard)

Über einen DynDNS-Anbieter kann Ihre FRITZ!Box unter einem festen Domainnamen aus dem Internet erreicht werden, obwohl sich die öffentliche IP-Adresse der FRITZ!Box regelmäßig ändert. Ihren Domainnamen und zugehörige Kontoinformationen erhalten Sie bei Ihrem DynDNS-Anbieter. So können die Benutzeroberfläche Ihrer FRITZ!Box sowie Anwendungen und Dienste einfach erreicht werden, sobald in der FRITZ!Box entsprechende Portfreigaben eingerichtet wurden.

☒ DynDNS aktiv

Geben Sie die Anmeldedaten für Ihren DynDNS-Anbieter an.

Update-URL:

Domainnamen:

Benutzername:

Kennwort:

✓ Kennwort gespeichert.
Zum Ändern neues Kennwort eingeben.

Verwerfen Übernehmen

Figure A.13.: FRITZ!Box DynDNS Setup

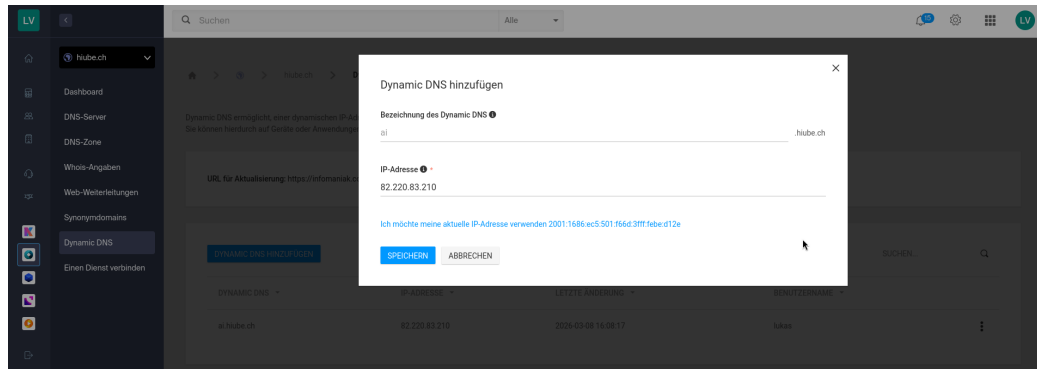


Figure A.14.: Infomaniak DynDNS Setup

Now that the domain name “ai.hiube.ch” points to the router in the home network, we need to redirect the HTTP(S) traffic to the LLM server. This can be achieved with port forwarding rules on the FRITZ!Box, as shown in the screenshot A.15.

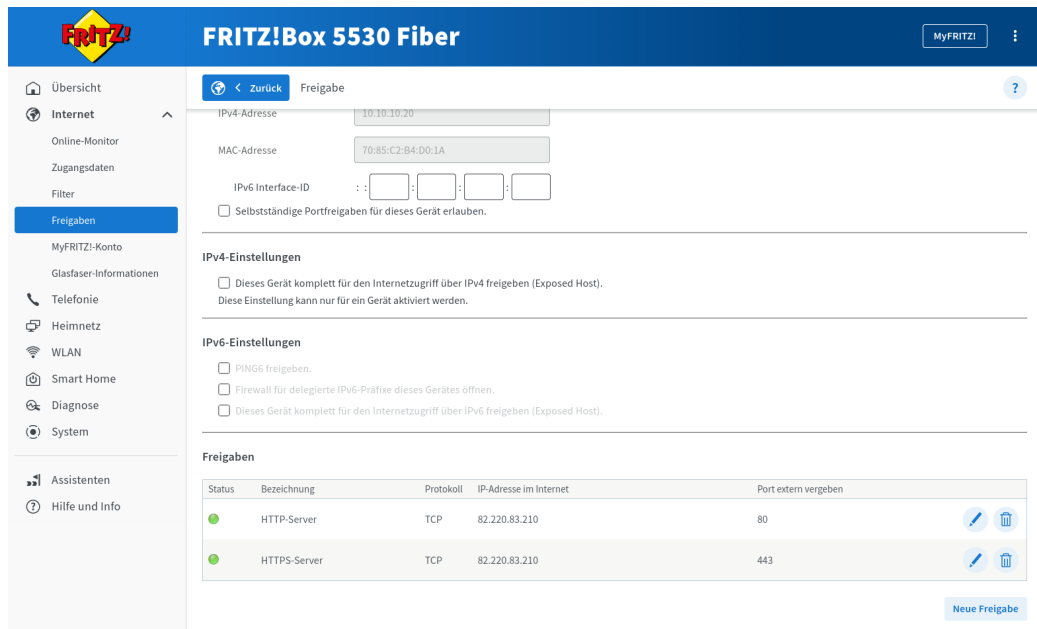


Figure A.15.: FRITZ!Box DynDNS Setup

The Open WebUI and Ollama API should already be reachable via “ai.hiube.ch”, but we will receive a security warning because there is no valid SSL certificate. The easiest way to generate the certificate, is to trigger certbot by restarting the “swag” service as shown in the listing below 1.

```
1 # Login as user ai and restart the swag service
2 podman-compose restart swag
```

Listing A.5: Example Python Script

A.9.3. Evaluation

For quickly evaluate models and assess their capabilities we can now use the Open WebUI served under “ai.hiube.ch”. The screenshot A.16 shows a quick test with “qwen2.5-coder:7B”.

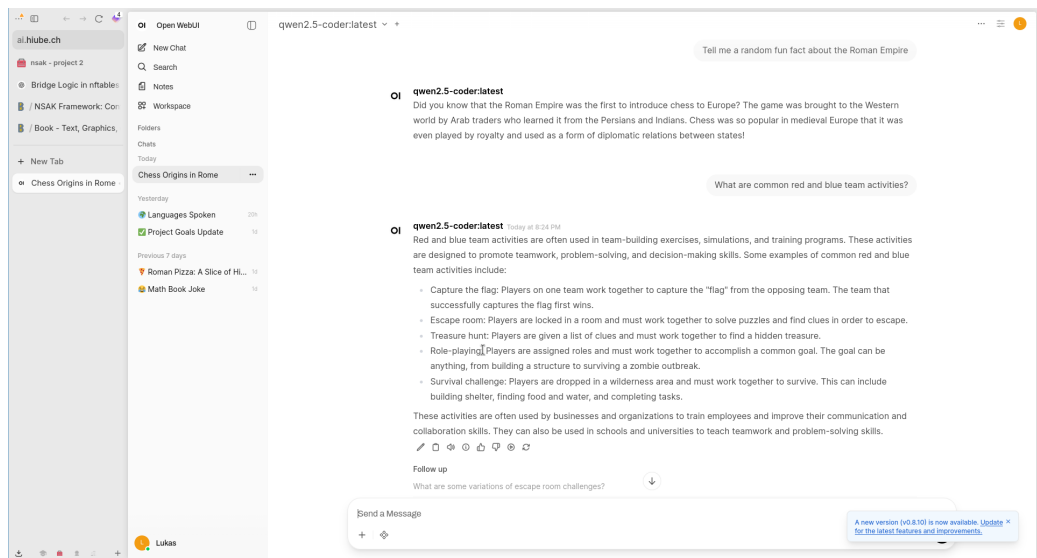


Figure A.16.: FRITZ!Box DynDNS Setup

Later on we can use the Ollama API served under “/llm/” as a backend for AI agents.